APPLICATION SECURITY

Application Security Testing

Business logic-aware testing of web apps, APIs, mobile, and source code — powered by AI SAST and ToIP.

Inside This Document

Key Benefits • Your Challenge • Services Overview • The Technieum Edge • Deliverables

Technieum Technologies LLC • www.technieum.com • Confidential

KEY BENEFITS

Why This Matters

Business Logic Intelligence

We extract your app's auth, authz, and transaction logic — then generate target-specific attack playbooks.

Agentic SAST Pipeline

Source code → logic extraction → ToIP playbooks → validated exploits. Fully automated then human-validated.

Zero False Positives

Every SAST finding, dynamic test, and SCA alert is manually validated. You fix real bugs only.

YOUR CHALLENGE

Your applications span web frontends, REST/GraphQL/SOAP APIs, mobile clients, and complex business logic:

- Business logic flaws that automated scanners miss
- Expanding API surfaces with complex authorization models
- Third-party dependency risks in your supply chain
- False positive noise consuming engineering time

Why Technieum as Your Trusted Partner

Technieum brings 6 proprietary AI platforms, an in-house R&D team actively hunting zero-days, and AI-powered methodologies that deliver validated, exploitable findings with guaranteed zero false positives — enabling your team to focus remediation effort where it matters most.

OUR SOLUTION

Services Overview

Technieum combines AI-powered static analysis with dynamic testing, manual code review, and SCA — all cross-correlated through ToIP intelligence.

1	**Web App Penetration Testing**	Comprehensive manual testing covering authentication mechanisms, session management, horizontal/vertical access control bypasses, business logic flaws (payment manipulation, workflow bypass, race conditions), file upload vulnerabilities, server-side request forgery, template injection, and application-specific attack scenarios beyond standard OWASP Top 10 coverage.
2	**API Testing (REST/GraphQL/SOAP)**	Dedicated API security assessment covering BOLA/IDOR vulnerabilities, broken authentication and authorization, excessive data exposure, mass assignment, injection attacks, rate limiting bypass, GraphQL-specific attacks (introspection abuse, query depth/batching), SOAP XML injection, and API-specific business logic flaws with full request/response evidence.
3	**Mobile Application Testing**	iOS/Android — binary analysis, reverse engineering, cert pinning bypass, insecure storage, runtime manipulation.
4	**Thick Client Testing**	Desktop app security — binary RE, memory analysis, IPC exploitation, local privilege escalation.
5	**Source Code Review (AI SAST)**	AI-powered static analysis that goes beyond pattern matching — our SAST engine understands authentication flows, authorization models, transaction logic, and data handling patterns. Identifies business logic vulnerabilities, tainted data flows, insecure cryptographic implementations, hardcoded secrets, and injection sinks with contextual exploitability scoring.
6	**Software Composition Analysis**	Dependency scanning with exploitability scoring and reachability analysis — which vulns are actually reachable.
7	**Architecture Security Review**	Auth/authz patterns, data flows, API gateway configs, microservices communication, secrets management.

THE TECHNIEUM EDGE

Why Technieum for Application Security

Our Methodology
Agentic SAST pipeline: source code → AI analysis → business logic extraction → ToIP playbooks → exploit creation → human validation.

Business Logic Extraction
We understand your app's auth, authz, and transaction logic before testing.

AI SAST & AI SCA
Proprietary static analysis with exploitability scoring and reachability analysis.

ToIP Attack Playbooks
15,000+ vulns — instant payloads, WAF bypasses, exploit chains for your stack.

Full Stack Coverage
Web + API + Mobile + Thick Client + Source Code + SCA in one engagement.

Agentic SAST Pipeline
Code → logic → playbooks → exploits. Automated, then human-validated.

Zero False Positives
Every finding manually validated. Real risk only.

Standards Alignment

Every Technieum engagement aligns with globally recognized security frameworks including OWASP Top 10, OWASP API Top 10, OWASP LLM Top 10, PTES, NIST CSF, NIST AI RMF, MITRE ATT&CK, CIS Benchmarks, IEC 62443, and ISO 27001:2022. Our team holds OSCP, OSEP, CRTE, CRTP, eWPTX, eCPPT, and CEH certifications. Technieum is ISO 9001:2015 and ISO 27001:2022 certified.

OUR METHODOLOGY

How We Deliver Results

Technieum's application security methodology follows a structured five-phase approach designed for web applications, APIs, mobile apps, and source code — combining AI-powered static analysis with deep manual testing.

Discover	Analyze	Attack	Report	Remediate
Asset enumeration	ToIP intelligence	Manual exploitation	CVSS/CWE scoring	AI-powered fixes
Tech fingerprinting	Logic extraction	Business logic test	PoC evidence	Stack-specific code
OSINT gathering	Threat modelling	Chain validation	Exec summary	Config guidance
Scope validation	Risk prioritization	Privilege escalation	Test case docs	Retest validation
Port scanning	Attack planning	Lateral movement	Playbook docs	Closure sign-off
Service detection	Playbook generation	Data exfiltration	Risk heatmap	Knowledge transfer

Phase 1 — Discover

Application reconnaissance maps all endpoints, authentication flows, API schemas (REST/GraphQL/SOAP), mobile app binary analysis, and technology stack fingerprinting. AI SAST performs initial source code analysis to extract business logic patterns.

Phase 2 — Analyze

AI SAST extracts authentication, authorization, and transaction logic from source code. ToIP generates application-specific attack playbooks. AI SCA maps dependency risks with exploitability scoring. Threat models are built against your application architecture.

Phase 3 — Attack

Manual exploitation of business logic flaws, authentication bypasses, authorization failures, injection chains, API-specific vulnerabilities (BOLA/IDOR, mass assignment), mobile client-side attacks, and complex multi-step exploitation chains.

Phase 4 — Report

Technical reports with API endpoint-specific findings, business logic test case documentation, SAST/SCA analysis results, CVSS-scored vulnerabilities with request/response PoC evidence, and application architecture risk assessment.

Phase 5 — Remediate

Framework-specific remediation guidance — React, Angular, Django, Spring, Node.js, iOS, Android patterns. Code-level fix examples, secure coding recommendations, and dependency upgrade paths. Retest validates every fix.

DELIVERABLES

What You Receive

Every engagement produces four comprehensive deliverables designed for different stakeholders — from technical teams requiring reproduction steps to executives needing business impact context.

Technical Report	Management Report	Threat Model Report	ToIP Playbook
CVSS-scored, CWE-mapped findings with proof-of-concept evidence and step-by-step reproduction instructions for every vulnerability discovered.	Executive-level risk summary with business impact analysis, prioritized recommendations, and strategic remediation roadmap for leadership.	Comprehensive threat landscape analysis with attack vectors mapped to MITRE ATT&CK framework specific to your environment.	Target-specific attack playbooks generated from 15,000+ real-world disclosed vulnerabilities via our RAG-powered intelligence engine.

- ✓ **Technical Report**
  Detailed findings with CVSS scoring, CWE mapping, proof-of-concept evidence, and step-by-step reproduction instructions.
- ✓ **Management Report**
  Executive-level risk summary with business impact analysis, prioritized recommendations, and strategic remediation roadmap.
- ✓ **Threat Model Report**
  Comprehensive threat landscape analysis specific to your environment, attack vectors, and adversary profiles mapped to MITRE ATT&CK.
- ✓ **ToIP Playbook Document**
  Target-specific attack playbooks generated from 15,000+ real-world disclosed vulnerabilities via our RAG-powered intelligence engine.

All deliverables are produced within the agreed timeline with milestone-driven tracking. Critical findings are escalated immediately via the OffSec Management Portal — you never wait for the final report to learn about urgent risks.

Ready to Secure Your Organization?

Partner with Technieum for AI-powered offensive security with zero false positives.

robert.a@technieum.com | syam.s@technieum.com